CaseVault

Secure Incident Evidence Exchange | Custom theme approval proposal

Course: CYC386 — Secure Software Design and Development **Instructor:** Engr. Muhammad Ahmad Nawaz

Team: [Team name / member names] **Submitted:** [Actual date]

Concept and practical scope

CaseVault is a compact internal incident-response evidence portal. Investigators upload incident logs or documents, record a SHA-256 integrity digest, and explicitly grant or revoke another registered analyst's access. Every sensitive action is authorised and audited. The sprint starts from a starter application and produces a demonstrably hardened service.

Proposed architecture

Browser-based UI → FastAPI (Python) application → SQLite metadata, access grants and audit records + private file storage. A small compiled C helper processes upload metadata, providing a realistic memory-unsafe legacy boundary. Docker supports reproducible setup; GitHub Actions runs tests, SAST and security gates; OWASP ZAP supplies DAST evidence.

Mandatory vulnerabilities: lab demonstration → secure remediation

- **Buffer Overflow:** Unbounded legacy C metadata copy → bounded parser and AddressSanitizer verification.
- **Command Injection:** Unsafe legacy external-helper invocation → fixed executable with argument arrays; no shell.
- **IDOR:** Manipulated evidence ID → ownership/explicit-share checks for every read or change.
- **CSRF:** Forged share/delete POST → verified anti-CSRF tokens and SameSite cookies.
- **Clickjacking:** Sensitive page framed externally → CSP frame-ancestors and X-Frame-Options headers.

The vulnerable examples will run only in isolated local lab exercises; they will not be included in the deployed service. Deliverables include PNE/CIA mapping, DFDs, STRIDE, two Attack Trees, CVSS v3.1 assessment, traceable PRs/Jira issues, before/after tests, a report and a narrated demonstration.

Approval requested: Confirm theme uniqueness and suitability for the five required vulnerability demonstrations.